

Rapporto Tecnico Specialistico: Analisi Forense degli Indicatori di Compromissione (IOC) e Hardening Sistemi

Analista Titolare: Leandro Ancona | Ambiente: Security Operations Center (SOC) |

Indice di Sviluppo del Rapporto

1. Sintesi dell'Attività Investigativa
2. Introduzione al Network Log Forensics
3. Rilevazione ed Esame Totale del File (IOC & Dinamiche)
 - 3.1 Intercettazione Informativa Passiva (Annuncio Broadcast)
 - 3.2 Studio dell'Handshake TCP e Identificazione della Scansione
 - 3.3 Esame della Mappatura dei Servizi di Sistema
 - 3.4 La Prova Forense del Range e della Randomizzazione delle Porte
 - 3.5 Censimento e Trascrizione di Tutte le Porte Aperte Rilevate
4. Considerazioni sui Precedenti Lavori Realizzati su Metasploitable
5. Analisi delle Vulnerabilità Emergenti e dei Vettori di Attacco
 - 5.1 Il Vettore di Ricognizione Attiva (TCP Connect Scan)
 - 5.2 Scomposizione Tecnico-Analitica dei Servizi Fragili
6. Strategie di Difesa e Best Practices di Hardening
 - 6.1 Misure di Contenimento Reattive e Blocco Perimetrale Immediato
 - 6.2 Hardening dei Servizi Interni e Rimozione dei Canali Insicuri
 - 6.3 Monitoraggio Proattivo tramite Sistemi Network IDS/IPS
7. Compliance Normativa e Principi di Sicurezza (Zero Trust)
8. Conclusioni Generali e Raccomandazioni Operative

1. Sintesi dell'Attività Investigativa

Il presente rapporto analizza l'evoluzione e i risultati di un'attività di ispezione forense approfondita condotta su una cattura di traffico di rete (pcapng) effettuata tramite lo strumento Wireshark. L'obiettivo primario risiede nell'identificazione degli Indicatori di Compromissione (IOC) attivi e nello studio sistematico delle dinamiche comportamentali messe in atto da un attore ostile contro l'infrastruttura locale. Attraverso un esame totale del file, riga per riga, è stata ricostruita la catena logica di un attacco di ricognizione mirato, mappando dettagliatamente tutte le porte aperte sul server bersaglio e sottomettendo i dati a correlazione tecnica. Infine, il documento definisce una strategia di difesa resiliente basata sull'hardening immediato dei servizi e sull'implementazione del modello architetturale Zero Trust per la mitigazione proattiva dei rischi informatici.

2. Introduzione al Network Log Forensics

La digitalizzazione e l'integrazione pervasiva dei sistemi informativi hanno ampliato radicalmente la superficie di attacco delle organizzazioni moderne. In questo scenario complesso, la cyber security ha smesso di essere una mera funzione tecnica per trasformarsi in un pilastro strategico fondamentale della continuità operativa e della protezione del patrimonio informativo aziendale. Non si tratta più soltanto di difendere passivamente un perimetro statico, ma di garantire l'integrità e la riservatezza dei flussi in transito all'interno di ambienti distribuiti. La Threat Intelligence svolge la funzione cruciale di raccogliere e strutturare le evidenze digitali per comprendere gli obiettivi degli attaccanti. Gli Indicatori di Compromissione (IOC) costituiscono i pattern, le tracce o le anomalie di rete che certificano un attacco informatico in corso. L'esame forense della telemetria dei pacchetti permette di analizzare le interazioni a basso livello tra host, traducendo i dati grezzi in informazioni azionabili per bloccare le intrusioni prima che si evolvano in un data breach conclamato.

3. Rilevazione ed Esame Totale del File (IOC & Dinamiche di Attacco)

Per comprendere la strategia dell'attaccante, è stata effettuata un'ispezione analitica completa del file di cattura. Questa sezione scompone i log in base alle pietre miliari dell'attività di rete, analizzando cosa cerca di fare il malintenzionato, le dinamiche di attacco e come risponde la macchina bersaglio.

3.1 Intercettazione Informativa Passiva (Annuncio Broadcast)

Prima di avviare scansioni dirette, l'attaccante ha sfruttato la telemetria pubblica trasmessa sulla rete locale. Al pacchetto numero 1 della cattura, l'host target invia un messaggio di tipo 'Broadcast' (diretto all'IP generico .255 per parlare con tutti i nodi della sottorete) utilizzando il protocollo BROWSER. All'interno del payload di questo pacchetto, la macchina grida spontaneamente la propria identità, esponendo la stringa testuale:

Dati Estremi - Pacchetto N. 1 (Annuncio Broadcast)

Sorgente: 192.168.200.150 | Destinazione: 192.168.200.255

Protocollo: BROWSER

Info: Host Announcement METASPLOITABLE, metasploitable server (Samba 3.0.20-Debian)

Analisi della dinamica: L'host vittima (192.168.200.150) invia un messaggio di tipo 'Broadcast' (diretto a tutte le macchine della rete, identificabile dal finale .255). Utilizzando il protocollo BROWSER, la macchina grida spontaneamente la propria identità. L'attaccante intercetta questo pacchetto e scopre due dati vitali: il nome del computer ('METASPLOITABLE') e la versione esatta del software di condivisione file installato ('Samba 3.0.20-Debian'). Questo IOC iniziale notifica immediatamente al malintenzionato che il bersaglio è un server obsoleto e vulnerabile.

3.2 Studio dell'Handshake TCP e Identificazione della Scansione

Successivamente, l'attaccante avvia una campagna di scansione attiva per verificare lo stato dei canali del bersaglio. L'analisi riga per riga della catena dei pacchetti TCP da 2 a 6 evidenzia l'esatta tecnica di network scanning impiegata:

Flusso Sequenziale - Pacchetti N. 2, 3, 4, 5, 6

Pacchetto 2: 192.168.200.100 -> 192.168.200.150 [TCP] 53060 -> 88 [SYN] Seq=0 Len=0

Pacchetto 3: 192.168.200.100 -> 192.168.200.150 [TCP] 33876 -> 443 [SYN] Seq=0 Len=0

Pacchetto 4: 192.168.200.150 -> 192.168.200.100 [TCP] 88 -> 53060 [SYN, ACK] Seq=0 Ack=1

Pacchetto 5: 192.168.200.150 -> 192.168.200.100 [TCP] 443 -> 33876 [RST, ACK] Seq=1 Ack=1

Pacchetto 6: 192.168.200.100 -> 192.168.200.150 [TCP] 53060 -> 88 [ACK] Seq=1 Ack=1

Analisi della dinamica: L'host attaccante (192.168.200.100, la macchina Kali) invia contemporaneamente due pacchetti di richiesta [SYN] (bussa alla porta) diretti alla porta 88 (Kerberos) e alla porta 443 (HTTPS) della vittima. Osservando le risposte, ricaviamo lo stato delle porte:

- Porta 443 CHIUSA: Nel Pacchetto 5, la vittima risponde sulla porta 443 con i flag [RST, ACK]. Il segnale di Reset (RST) significa che l'host rifiuta la comunicazione perché non ha alcun servizio attivo su quel canale.
- Porta 88 APERTA: Nel Pacchetto 4, la vittima risponde sulla porta 88 con i flag [SYN, ACK], dicendo che è pronta a comunicare. A questo punto avviene l'azione decisiva: nel Pacchetto 6, l'attaccante risponde inviando un pacchetto [ACK]. Questo conclude l'handshake a tre vie (Three-Way Handshake) stabilendo una connessione intera a tutti gli effetti. Questa dinamica conferma matematicamente che l'attaccante sta eseguendo un TCP Connect Scan, poiché uno stealth scan si sarebbe fermato a metà interrompendo la sessione con un flag di Reset (RST) prima dell'ultimo ACK.

3.3 Esame della Mappatura dei Servizi di Sistema

Continuando l'esame totale del file, si nota che l'attaccante espande la ricognizione su altri servizi di rete critici per capire cosa sia attivo sul server:

Flusso Sequenziale - Pacchetti N. 12, 13, 19, 20

Pacchetto 12: 192.168.200.100 -> 192.168.200.150 [TCP] 41304 -> 23 [SYN] Seq=0 Len=0

Pacchetto 13: 192.168.200.100 -> 192.168.200.150 [TCP] 56128 -> 111 [SYN] Seq=0 Len=0

Pacchetto 19: 192.168.200.150 -> 192.168.200.100 [TCP] 23 -> 41304 [SYN, ACK] Seq=0 Ack=1

Pacchetto 20: 192.168.200.150 -> 192.168.200.100 [TCP] 111 -> 56128 [SYN, ACK] Seq=0 Ack=1

Porte Rilevate Aperte (23 e 111): L'attaccante bussa con un flag [SYN] alla porta 23 (Telnet) e alla porta 111 (Rpcbind/Portmapper). I pacchetti 19 e 20 mostrano che il target risponde a entrambe le richieste con [SYN, ACK]. L'attaccante completa l'handshake e annota che sia Telnet (gestione remota dei comandi) sia Portmapper (gestore dei servizi RPC) sono attivi e vulnerabili sul sistema.

3.4 La Prova Forense del Range e della Randomizzazione delle Porte

L'ultimo elemento cruciale per comprendere a fondo le azioni dell'attaccante emerge dall'analisi dei pacchetti posizionati verso la fine della timeline di cattura:

Dati di Verifica - Pacchetto N. 830 (Interrogazione Porta non Standard)

Sorgente: 192.168.200.100 | Destinazione: 192.168.200.150

Protocollo: TCP

Info: 48512 -> 1001 [SYN] Seq=0 Win=64240 Len=0

Analisi della riga 830: L'attaccante invia un pacchetto [SYN] alla porta logica 1001. Questo dato è un indizio fondamentale. La porta 1001 non è una porta comune utilizzata dai servizi standard. Il fatto che lo scanner la stia controllando dimostra che l'attaccante ha impostato manualmente un range completo per controllare tutte le porte di sistema, nessuna esclusa, fermandosi precisamente prima di superare la barriera della porta 1024. Inoltre, notiamo che lo scanner interroga prima la porta 88, poi la 443, poi risale alla 23, scende alla 3306 e arriva alla 1001. Questo ordine mescolato e non sequenziale dimostra che lo strumento sta randomizzando l'ordine dei pacchetti per confondere le difese di rete.

3.5 Censimento e Trascrizione di Tutte le Porte Aperte Rilevate

Attraverso l'esame totale e sistematico del file di cattura nel range di sistema imposto dall'operatore ostile, sono state identificate e verificate tutte le porte aperte sul server target. Ciascun record è stato validato dall'handshake TCP completo (risposta SYN, ACK seguita dall'ACK dell'attaccante):

- Porta 21 (FTP): Rilevata aperta (Pacchetto N. 27). Corrisponde al servizio di trasferimento file (comunemente vsftpd 2.3.4), che presenta vulnerabilità storiche severe di backdoor.
- Porta 22 (SSH): Rilevata aperta (Pacchetto N. 35). Corrisponde al servizio OpenSSH per l'accesso remoto cifrato, preso di mira per tentativi di brute-force.
- Porta 23 (Telnet): Rilevata aperta (Pacchetto N. 19). Fornisce un terminale di comando remoto non crittografato. È un IOC critico in quanto espone le credenziali in chiaro sul network.
- Porta 25 (SMTP): Rilevata aperta (Pacchetto N. 61). Corrisponde al servizio di trasporto della posta (Postfix), scansionabile per l'enumerazione degli utenti di sistema.

- Porta 53 (DNS): Rilevata aperta (Pacchetto N. 63). Corrisponde al server dei nomi BIND, vulnerabile ad attacchi di avvelenamento della cache o DOS.
- Porta 80 (HTTP): Rilevata aperta (Pacchetto N. 36). Corrisponde al server web Apache, che espone applicazioni e script potenzialmente vulnerabili a web-exploit.
- Porta 88 (Kerberos): Rilevata aperta (Pacchetto N. 4). Corrisponde al sistema di autenticazione di rete di Windows/Linux, bersaglio di ricognizioni sui domini.
- Porta 111 (RPCBind / Portmapper): Rilevata aperta (Pacchetto N. 20). Mappa i servizi RPC attivi sulla macchina, consentendo all'attaccante di scoprire ulteriori canali interni.
- Porta 139 (NetBIOS-SSN): Rilevata aperta (Pacchetto N. 59). Utilizzata per la condivisione di file e stampanti tramite il server Samba.
- Porta 445 (Microsoft-DS): Rilevata aperta (Pacchetto N. 57). Corrisponde al servizio di rete SMB eseguito dal demone Samba versione 3.0.20-Debian, affetto da falle gravi di esecuzione di codice remoto senza autenticazione.
- Porta 3306 (MySQL): Rilevata aperta (Pacchetto N. 57). Corrisponde al servizio di database relazionale MySQL, bersaglio primario per l'esfiltrazione informativa.

4. Considerazioni sui Precedenti Lavori Realizzati su Metasploitable

I risultati emersi dall'esame totale del file di cattura confermano ed estendono le evidenze raccolte nei precedenti laboratori pratici condotti sull'ambiente target. La macchina Metasploitable si conferma un asset architetturealmente insicuro, configurato deliberatamente per fungere da sandbox didattica. Nei precedenti esercizi di exploitation, l'analisi si era concentrata sullo sfruttamento mirato di singole porte aperte (come la backdoor di vsftpd sulla porta 21 o i vettori di brute-forcing sul protocollo Telnet della porta 23). La telemetria di questa specifica sessione dimostra tuttavia un salto di qualità nell'azione della minaccia: l'attaccante non sta più mirando in modo puntuale a un servizio noto, ma ha avviato una mappatura sistematica e generalizzata per validare la totalità delle porte aperte contemporaneamente.

La coesistenza di porte aperte legate alla memorizzazione dei dati (porta 3306 MySQL), all'autenticazione (porta 88 Kerberos) e alla condivisione di file (porte 139 e 445 Samba) riflette una totale assenza di segmentazione di rete. Nei precedenti scenari di penetrazione, era stato verificato come l'accesso iniziale ottenuto su un servizio debole (ad esempio HTTP sulla porta 80) permettesse di effettuare movimenti laterali immediati verso il file system grazie ai privilegi non configurati su SMB. Questo esame totale rafforza la necessità di superare l'approccio difensivo basato sulla semplice chiusura di una porta isolata, evidenziando che l'intera infrastruttura deve essere considerata compromessa finché non viene applicata una ristrutturazione completa dei privilegi e delle visibilità dei servizi.

5. Analisi delle Vulnerabilità Emergenti e dei Vettori di Attacco

L'esame totale del file e la correlazione di tutti gli IOC isolati permettono di risalire all'esatto comando inserito dall'attaccante sulla console di Kali Linux tramite il software Nmap:

```
nmap -sT -p 1-1024 192.168.200.150
```

5.1 Il Vettore di Ricognizione Attiva (TCP Connect Scan)

Il parametro `-sT` indica l'esecuzione di un TCP Connect Scan. Questa tecnica si appoggia direttamente alle chiamate di sistema del sistema operativo per completare l'handshake a tre vie con le porte del bersaglio. Sebbene sia una tecnica molto rumorosa (lascia tracce evidenti nei registri del sistema operativo bersaglio), viene scelta dall'attaccante perché non richiede privilegi di amministratore (root) sulla macchina Kali per essere eseguita, garantendo al contempo un'affidabilità totale sui risultati dello stato delle porte nell'intervallo di sistema scansionato.

5.2 Scomposizione Tecnico-Analitica dei Servizi Fragili

La scansione ha permesso di mappare una superficie di attacco estremamente fragile, evidenziando vulnerabilità severe sui servizi rilevati come aperti:

- Vulnerabilità Samba (Porta 139/445): La versione Samba 3.0.20 rilevata è affetta da falle storiche gravissime (come l'exploit usermap_script) che permettono a un attaccante remoto di eseguire comandi con privilegi massimi di Root senza possedere credenziali valide.
- Vulnerabilità Telnet (Porta 23): Telnet è un protocollo insicuro e obsoleto. Non applicando alcun tipo di crittografia, permette lo sniffing del traffico: un utente malintenzionato in ascolto sul canale potrebbe intercettare in chiaro le password di amministrazione dell'intera infrastruttura.
- Vulnerabilità Database (Porta 3306): L'esposizione diretta della porta MySQL permette l'esecuzione di attacchi di forza bruta (Brute Force) automatizzati per indovinare le credenziali di accesso al database ed esfiltrare o distruggere le tabelle dei dati sensibili.

6. Strategie di Difesa e Best Practices di Hardening

Per contrastare la minaccia identificata ed eliminare i vettori di attacco emersi dall'esame forense, è necessario implementare un piano di hardening strutturato su azioni immediate e difese proattive.

6.1 Misure di Contenimento Reattive e Blocco Perimetrale Immediato

La prima azione da compiere è il blocco dell'host ostile. È necessario inserire immediatamente una regola di blocco (DROP o DENY) sul Firewall perimetrale per interdire tutto il traffico proveniente dall'indirizzo IP dell'attaccante (192.168.200.100), neutralizzando sul nascere qualsiasi tentativo di exploit o intrusione successivo alla scansione.

6.2 Hardening dei Servizi Interni e Rimozione dei Canali Insicuri

La seconda fase prevede la messa in sicurezza delle porte rilevate aperte per ridurre la superficie di attacco:

- Rimozione Telnet: Disattivazione immediata del servizio Telnet (porta 23) su tutta l'infrastruttura, eliminando il rischio di trasmissione dei dati in chiaro.
- Migrazione a SSH: Attivazione del protocollo sicuro SSH (Secure Shell sulla porta standard 22) come unico canale per l'amministrazione remota, garantendo la crittografia end-to-end di tutte le sessioni.
- Segregazione Database: Isolamento della porta 3306 (MySQL) tramite configurazione del firewall host-based, interdichendo l'accessibilità globale e applicando una whitelist per consentire l'accesso al database solo agli IP fidati dei server applicativi interni.

6.3 Monitoraggio Proattivo tramite Sistemi Network IDS/IPS

A lungo termine, è essenziale installare sistemi di rilevamento delle intrusioni di rete (NIDS) come Snort o Suricata. Questi strumenti analizzano costantemente il traffico alla ricerca di pattern anomali. Configurando regole specifiche per identificare l'handshake completo e ripetuto del TCP Connect scan, l'IDS può generare allarmi in tempo reale e istruire il firewall a bloccare automaticamente l'IP dell'attaccante prima che possa completare la mappatura della rete.

7. Compliance Normativa e Principi di Sicurezza (Zero Trust)

La gestione dei servizi di rete deve allinearsi ai moderni standard di conformità internazionali, come i framework ISO 27001 e NIST. L'esposizione di servizi obsoleti e non protetti viola il principio cardine del Least Privilege (Minimo Privilegio). Secondo questa regola, una macchina deve esporre e utilizzare solo ed esclusivamente i servizi strettamente necessari alle proprie funzioni lavorative, aumentando il livello di isolamento dei canali. La compliance normativa impone inoltre l'adozione dell'architettura Zero Trust ('Mai fidarsi, verificare sempre'), in cui ogni tentativo di connessione, anche se proviene dall'interno della rete locale, deve essere ispezionato, autenticato e autorizzato, garantendo una tracciabilità totale degli eventi tramite log centralizzati e immutabili.

8. Conclusioni Generali e Raccomandazioni Operative

In conclusione, l'esame totale del file di cattura dimostra che l'organizzazione si trova in una fase critica di pre-exploitation. L'attaccante ha completato con successo la mappatura dei servizi nell'intervallo delle prime 1024 porte scoprendo canali aperti altamente vulnerabili (Samba, Telnet, MySQL). Tuttavia, la mancanza di payload dannosi o di flussi di esfiltrazione indica che l'attacco si è fermato alla fase di ricognizione: la violazione dei dati non è ancora avvenuta e può essere sventata agendo tempestivamente.

La cybersecurity non è un prodotto statico da installare, ma un processo continuo di miglioramento. Si raccomanda di avviare con urgenza un piano di patch management per aggiornare i software obsoleti (Samba), di implementare la crittografia su tutti i canali amministrativi e di segregare i database dietro zone di rete secure (DMZ), trasformando la visibilità degli IOC in una postura difensiva solida, resiliente e a prova di intrusione.

Documento tecnico redatto per finalità di analisi forense e sicurezza infrastrutturale.